Atividade de Engenharia Reversa

Sistema da Oficina Mecânica AutoCerta

Contexto

A oficina AutoCerta recebeu de um fornecedor um sistema web **já pronto**, mas **sem nenhuma documentação**. Você foi contratado(a) para descobrir como o sistema funciona e produzir a documentação técnica que está faltando, a partir do código-fonte e do comportamento da aplicação em execução.

Como executar o sistema

- Precisa do Node.js 22.13 ou superior (confira com `node -v`). O aviso "ExperimentalWarning: SQLite" ao iniciar é normal.
- Dentro da pasta **sistema**, rode `npm install` e depois `npm start`.
- Acesse `http://localhost:3000`.
- Logins de teste estão no arquivo LEIA-ME.txt.

O que você deve entregar

#	Entregável	Descrição
1	Levantamento de requisitos	Lista de requisitos funcionais (RF) e regras de negócio que o sistema atende, escritos por você após usar e ler o código.
2	Modelo de dados	DER (diagrama entidade-relacionamento) do banco, com chaves primárias, chaves estrangeiras, tipos e cardinalidades. Dica: o banco nasce do arquivo db/oficina_db.sql.
3	Mapa da API	Tabela com todas as rotas do back-end: método, caminho, o que recebe, o que devolve, validações e códigos de resposta.
4	Mapa do front-end	Para cada página HTML: qual script usa, quais rotas chama e o que acontece em cada ação do usuário.
5	Segurança	Explique como funcionam: autenticação, expiração de sessão, hash de senha e criptografia do CPF. Aponte ao menos 3 pontos que você melhoraria.
6	Casos de teste	Mínimo de 15 casos (ID, requisito, procedimento, resultado esperado) e o resultado real após executá-los.
7	Diagrama de fluxo	Fluxo de uma funcionalidade à sua escolha, do clique no navegador até o banco de dados e de volta.
8	Código comentado	Entregue uma cópia do código-fonte com **comentários explicando o que cada parte faz**: arquivos, funções, rotas, consultas SQL e regras de validação. Explique o **porquê**, não apenas o quê.

Perguntas para investigação

- O que acontece se a sessão expirar enquanto você está em uma tela interna? Onde isso é tratado, no front ou no back?
- Por que a busca de clientes por CPF é feita no código e não direto em SQL?
- Por que a listagem de agendamentos aparece agrupada por mês? Qual parte do código faz a ordenação e qual faz o agrupamento visual?
- O que impede cadastrar um veículo sem cliente? Existe proteção em mais de uma camada?
- Por que a função `esc()` existe? Que ataque ela evita?

- Há regras que existem só no front-end ou só no back-end? Quais?

Critérios de avaliação

Critério	Peso
Precisão e completude dos requisitos e regras de negócio	15%
Correção do DER e do mapa da API	20%
Análise de segurança e justificativas	15%
Qualidade e cobertura dos casos de teste	20%
Código comentado (cobertura, clareza e correção dos comentários)	15%
Clareza, organização e evidências (prints, trechos de código)	10%
Uso do Git/GitHub (commits frequentes, mensagens claras, README e .gitignore)	5%

Entrega: via repositório no GitHub, com o link enviado no Google Classroom (veja as instruções da atividade).
Regras: não é permitido pedir a documentação original. Toda afirmação deve ser comprovada por um trecho do código ou por um teste executado.